応用情報技術者試験　テクノロジ系　#11

セキュリティ

用語集まとめ ― 過去問10回分（令和3〜7年度）で出たところを中心に



全体像 シラバスの5つの小分類で読む

1 情報セキュリティ
特性・攻撃手法・暗号・認証・PKI（午前の半分近く）

2 情報セキュリティ管理
リスクマネジメント・CSIRT/PSIRT・組織と制度

3 セキュリティ技術評価
CVE/CVSS・ファジング・耐タンパ性・CC

4 情報セキュリティ対策
WAF/IDS/IPS・ランサムウェア対策・TPM・SBOM

5 セキュリティ実装技術
SPF/DKIM・DNSSEC・IPsec/TLS・cookie・VLAN

午前での出方	
問題数	毎回 約10問（問35〜46あたり）
同じ問題の再出題	10回の中で6組（例：サイドチャネル攻撃、SPF、デジタルフォレンジックス）
選択肢の作り方	誤りの選択肢は「隣の技術の説明」。例：DNSSECの問題に、ポート番号のランダム化・SPF・DKIMの説明が並ぶ

この資料の読み方：1枚に1つのメッセージ。見出しの一文を覚えれば、本番で選択肢を見分けられるようにしてある。

過去問の出題傾向 令和3年春〜令和7年秋の10回・101問を分類

テーマ	問題数	よく出る論点
攻撃手法	約21	サイドチャネル攻撃（4回）、パスワード攻撃、サイバーキルチェーン、オープンリゾルバ
対策の製品・技術	約24	WAF、VDI、WORM、TPM、セキュアブート、SBOM、IPsec、cookie
管理・組織・規格	約19	JIS Q 27000の特性、JIS Q 31000、CSIRT/PSIRT、JPCERT/CC、JVN
認証・署名・PKI	約16	署名鍵と検証鍵、OCSP/CRL、SAML、3Dセキュア、チャレンジレスポンス
技術評価	約10	CVE/CVSS、ファジング（3回）、耐タンパ性（3回）
メール・DNS	約9	SPF/DKIM、サブミッションポート、DNSSEC（3回）

ほぼ毎回出る：サイドチャネル攻撃／DNSSECとDNSキャッシュポイズニング／SPF・DKIM／JIS Q 27000・31000の定義

最近増えた：SBOM、CSPM、ディープフェイク、ダークネット、セキュリティクリアランス、PSIRT、CRYPTREC暗号リスト

落とし穴：名前は知っていても、選択肢が「隣の技術の正しい説明」になっていると迷う。この資料は「何と何を見分けるか」で書いている。

第1章

情報セキュリティ

特性の定義 ／ マルウェア ／ 攻撃手法 ／ 暗号とハッシュ ／ 認証 ／ PKI



特性は「定義文の決まり文句」で当てる JIS Q 27000

特性	試験に出る定義文	見分け方
機密性	認可されていない個人，エンティティ又はプロセスに対して，情報を使用させず，また，開示しない	「認可されていない者に〜しない」
可用性	認可されたエンティティが要求したときに，アクセス及び使用が可能である	「認可された者が要求したとき使える」
完全性	正確さ及び完全さ	改ざんされていない
真正性	エンティティは，それが主張するとおりのものである	なりすましでない
信頼性	意図する行動と結果とが一貫している	期待どおり動く
否認防止	ある利用者があるシステムを利用したという事実が証明可能である	後から「やっていない」と言わせない

過去問：R3秋 問39（否認防止）、R5秋 問40（機密性）、R7秋 問41（真正性＝b・信頼性＝a の組合せ）。**誤りの選択肢は残りの特性の定義文**なので、6つの文を丸ごと覚えるのが近道。

マルウェアは「寄生するか・自分で広がるか・遠隔操作か」で分ける

名前	見分けるポイント
ウイルス	他のファイルに**寄生**する
ワーム	寄生せず、**自分で**ネットワークに広がる
トロイの木馬	役に立つソフトに**見せかける**。増殖しない
ボット／RAT	外から**遠隔操作**される。指令はC&Cサーバ
ルートキット	侵入の痕跡を**隠す**道具一式
バックドア	再び入るための**裏口**
ファイルレス	ファイルを残さず**メモリ上**や正規ツールで動く

ボットネットのしくみ

攻撃者
指令を出す

↓

C&Cサーバ
情報収集・攻撃活動を指示する（R5春 問36）

↓

ボットに感染した多数のPC
DDoS攻撃・スパム送信・情報の窃取

エクスプロイトコード＝脆弱性を悪用するコード。検証にも使える（R6秋 問46）。誤りの選択肢は「マルウェア定義ファイル」「HMAC」「ワンタイムパスワード」。

🥷 サイバーキルチェーンは7段階の順番で覚える

①偵察
公開情報・SNSで調べる
→
②武器化
ファイルにマルウェアを仕込む
→
③配送
メールを送りつける
→
④エクスプロイト
脆弱性を突いて実行させる

⑤インストール
マルウェアを住み着かせる
→
⑥C&C
遠隔操作の通信を確立
→
⑦目的の実行
情報を盗んで送り出す

R4春 問37「偵察」: 社員のSNS上の経歴・肩書から関係者を洗い出す。
誤りの選択肢 → 脆弱性で侵入(④)、メール送付(③)、「2番目の段階」でPDFに仕込む(②武器化)

R7秋 問36「エクスプロイト」: OSの脆弱性を悪用し攻撃ツールを実行させる。
誤りの選択肢 → 公開情報で調査(①)、秘密情報を送信(⑦)、マルウェア付きメール(③)

フットプリンティング=攻撃前の下調べ(偵察に当たる)。R3春 問38で、ハクティビズムやログの偽装と並べて出た。

🔢 パスワード攻撃は「何を固定して何を変えるか」で見分ける

攻撃	固定	変える・使う
ブルートフォース	ID	あらゆる文字の組合せ
辞書攻撃	ID	単語・人名などのリスト
リバースブルートフォース	パスワード	IDを次々に（ロックが効かない）
パスワードリスト攻撃	漏れたIDとPWの組	別のサイトで試す（使い回し狙い）
レインボーテーブル攻撃	盗んだハッシュ値	平文とハッシュの**チェーン**の表で逆引き

守る側の対策も4択で並ぶ（R7春 問44）	
ソルト	利用者ごとに違う文字列を**付け足して**からハッシュ化 → レインボーテーブルが使えない
ストレッチング	ハッシュ化を**繰り返す** → 1回の試行が遅くなる
アカウントロック	一定回数失敗で止める → 総当たりに有効
秘密の質問	普段と違うログインで追加質問（リスクベース認証）

過去問：R4春 問42＝R5秋 問36（レインボー）、R6秋 問40（パスワードリスト）。誤りの選択肢は、この表の別の行の説明。

Webの攻撃は「入力を何として解釈させるか」で名前が変わる

攻撃	入力に混ぜるもの → 解釈するところ	対策
SQLインジェクション	SQL文の断片 → データベース	プレースホルダ
OSコマンドインジェクション	「;cat /etc/passwd」 → サーバのシェル（R7春 問36）	シェルを起動する機能を使わない（R7春 問42）
ディレクトリトラバーサル	「../」 → ファイルのパス	ファイル名にディレクトリを含めない
クロスサイトスクリプティング	スクリプト → 閲覧者のブラウザ	出力時のエスケープ、HttpOnly属性
HTTPヘッダインジェクション	改行コード → HTTPレスポンスヘッダ	ヘッダ出力用の関数を使う
バッファオーバーフロー	長すぎるデータ → メモリ	入力長の確認

利用者をだます系：CSRF（意図しないリクエストを送らせる）、クリックジャッキング（透明なページを重ねる → X-Frame-Options、R3春 問37）

オープンリダイレクト：正規サイトの「転送機能」を踏み台に偽サイトへ（R3秋 問44）。偽リンクだけならただのフィッシング。

🌐 DNSキャッシュポイズニングは「偽の応答を先に覚え込ませる」攻撃



対策	防げる理由	過去問
送信元ポート番号とDNSヘッダのIDを**ランダム**にする	偽の応答を当てにくくなる（53番に固定は逆効果）	R6秋 問42
DNSSECで応答の署名を検証する	偽の応答は署名が合わない	R5秋 問45、R6春 問37、R6秋 問44

オープンリゾルバは別の問題：誰の問合せにも答えるので、送信元を偽った問合せでDNSリフレクション攻撃の踏み台になる（R4秋 問36）。

サイドチャネル攻撃は「物理量」、解読法は「数式」

サイドチャネル攻撃（正解になる側）	
電力解析攻撃	消費電力を測る
タイミング攻撃	処理時間の差を測る
テンペスト攻撃	漏れる電磁波を受信
プローブ攻撃	チップに探針を当てる
エラーメッセージ	エラーの違いから推測

誤りの選択肢になる側	
線形解読法	暗号化関数を**線形近似**
差分解読法	平文の**差**と暗号文の**差**
選択平文攻撃	選んだ平文と暗号文から鍵を推測
総当たり	あり得る鍵を全部試す
そのほか	トラッシング、中間者攻撃、のぞき見、電波妨害

4回出た：R4秋 問37、R5秋 問41＝R7春 問37（IoT機器の電磁波）、R7秋 問38（消費電力の測定と統計処理）。「物理的に漏れるもの」を探せば必ず当たる。

守る側：耐タンパ性（プローブ検知で消去・処理時間を一定にする・シールド）。

🔒 暗号は「鍵が同じか別か」と「鍵の数」を押さえる

	共通鍵暗号	公開鍵暗号
鍵	暗号化と復号で同じ	公開鍵と秘密鍵の組
速さ	速い	遅い
n人の鍵の数	**n(n−1)/2**	**2n**（R6春 問38）
代表	AES	RSA・楕円曲線暗号

10人なら　共通鍵 45個　／　公開鍵 20個

楕円曲線暗号（R5秋 問37）：RSAより**短い鍵長**で同じ安全性。誤りの選択肢 →「共通鍵暗号方式である」「総当たりで解けないと証明済み」「復号鍵を秘密にしなくてよい」

ハイブリッド暗号：本文は共通鍵で暗号化し、その共通鍵を受信者の公開鍵で暗号化して渡す。

CRYPTREC暗号リスト（R7春 問35）：電子政府推奨暗号リスト＝利用実績が十分で推奨するもの／推奨候補暗号リスト＝安全性は確認済みだが実績はこれから／運用監視暗号リスト＝互換性維持のために使うもの。

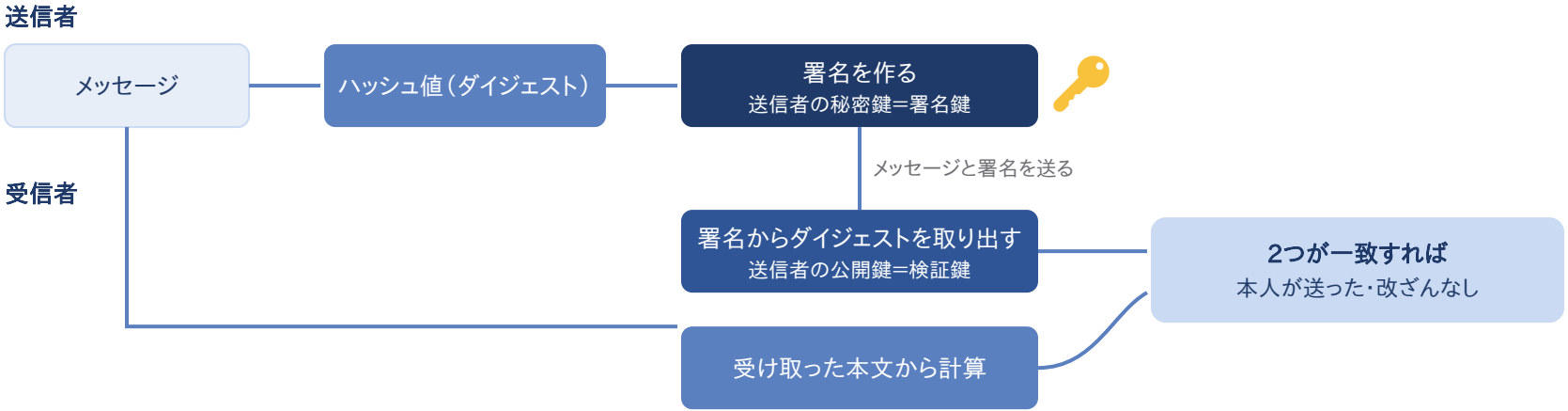
ハッシュの3性質と、MAC・署名の違い

ハッシュ関数の性質（R3春 問40）	
原像計算困難性（一方向性）	ハッシュ値 → 元のメッセージが見つからない
第二原像計算困難性	あるメッセージと同じハッシュ値の**別の**メッセージが見つからない
衝突発見困難性	同じハッシュ値になる**2つの組**を自由に選んでも見つからない

改ざんを見つける3つの方法		
	鍵	**否認防止**
ハッシュ値だけ	なし	×（作り直せる）
MAC・HMAC	共通鍵	×（相手も作れる）
デジタル署名	送信者の秘密鍵	○

R6秋 問46の誤りの選択肢ウ「メッセージとシークレットデータから計算されるハッシュコード」＝HMAC。**チャレンジレスポンス認証**もハッシュを使うが、目的は認証（R4春 問38）。

署名は「送信者の秘密鍵」、暗号化は「受信者の公開鍵」



R5春 問38：検証鍵は**送信者の公開鍵**で、**受信者**がダイジェストを取り出すのに使う。「送信者の秘密鍵で作成」は署名鍵の説明なので、検証鍵を問う問題では誤り。

R4春 問39の罠：署名鍵で暗号化しても誰でも公開鍵で戻せるので秘匿にはならない。改ざんの**有無**は分かるが**場所**は分からない。

認証方式は「何を毎回変えるか」「いつ追加するか」で見分ける

方式	しくみ	過去問
チャレンジレスポンス	サーバの乱数（チャレンジ）とパスワードを演算して返す。パスワードは流れない	R4春 問38
ワンタイムパスワード	トークンが毎回違う数字を表示	R4春 問38の誤りの選択肢
リスクベース認証	普段と違う端末・場所のときだけ追加の認証	R3春 問39
3Dセキュア2.0	取引履歴・端末情報から高リスクのときだけカード会社が追加認証	R6春 問35、R3秋 問42
多要素認証	知識・所有・生体の異なる2種類以上を**常に**併用	R3春 問39の誤りの選択肢
FIDO2	端末で生体認証し、公開鍵暗号でサーバに証明。パスワード不要	シラバス用語

カード決済の見分け：ネット（非対面）で盗まれたカード → 3Dセキュア。券面のセキュリティコード・有効期限は盗んだ人にも見える。店頭（対面）→ ICチップ＋オフラインPIN（R3春 問43）。

🔑 SAMLはパスワードではなく「認証結果」を渡す

①利用者がクラウドにアクセス → ②クラウド（SP）が社内の認証サーバへ転送 → ③社内の認証サーバ（IdP）がID・パスワードで認証 → ④認証結果（アサーション）をブラウザ経由でクラウドへ

R6秋 問37の選択肢	
ア	クラウドがID・パスワードを要求 → ×渡さない
イ	認証サーバがクラウドにID・PWを送信 → ×
ウ	認証結果をクライアント経由で送信 → **正解**
エ	パスワード+乱数のハッシュ → チャレンジレスポンス

似た仕組み	
SAML	認証・認可の情報をXMLで交換（R4春 問36）
OAuth	パスワードを渡さずアクセスを**認可**
OpenID Connect	OAuthに**認証**を足したもの
リバースプロキシ型SSO	プロキシが認証してIDをWebサーバに渡す（R4春 問41）

証明書は「何を証明するか」、失効は「一覧か問合せか」

証明書	証明するもの
サーバ証明書	Webサーバが本物であること
EV SSL証明書	組織の実在を厳格に審査したサーバ証明書
クライアント証明書	利用者・端末が本物であること
コードサイニング証明書	ソフトウェアの**発行元**と改ざんなし（R7秋 問37）
ルート証明書	信頼の起点。OS・ブラウザに組込み済み

	CRL	OCSP
方法	失効リストを取り寄せる	1枚ずつオンラインで問い合わせる
載るもの	有効期限**内**に失効した証明書のシリアル番号	失効しているかどうかの状態
過去問	R7秋 問39	R4秋 問38、R7春 問38

CRLの罠：期限切れの証明書は載せない。「全証明書の有効期限を載せる」「失効後1年間」は誤り。認証局の公開鍵が組み込まれていても、失効の確認は別に要る。

TLSのクライアント認証の順番（R3春 問45）：サーバ証明書を送る → クライアント証明書を送る → サーバがクライアントを認証。

第2章

情報セキュリティ管理

リスクマネジメント ／ インシデント対応 ／ CSIRT・PSIRT ／ 組織と制度 ／ ガイドライン



リスクアセスメント＝特定・分析・評価。対応は含まない

リスク特定
発見・認識・記述する

→

リスク分析
起こりやすさ×結果でリスクレベルを決める

→

リスク評価
リスク基準と比べ、対応の要否と優先順位

⇒

リスク対応
アセスメントの外

R6春 問40「リスク特定で考慮する事項」	
ア 結果の性質及び大きさ	→ 分析
イ 残留リスクが許容可能か	→ 対応
ウ 資産及び組織の資源の性質及び価値	→ **特定（正解）**
エ 事象の起こりやすさ及び結果	→ 分析

R4春 問43 用語の定義	
リスクレベル	結果とその起こりやすさの組合せで表したリスクの大きさ
脆弱性	脅威に付け込まれる資産・管理策の弱点
リスク基準	重大性を評価する目安とする条件

R4秋 問41：アセスメントの構成は「特定・分析・評価」。「受容」「対応」が入った選択肢は全部誤り。

リスク対応は「やめる・減らす・分ける・受け入れる」

対応	すること	例
リスク回避	原因となる活動そのものを**やめる**	個人情報を扱うサービスを終了する
リスク低減	対策で起こりやすさ・影響を**小さくする**	暗号化、バックアップ、教育、WAF
リスク共有（移転）	他者と**分け合う**	サイバー保険、外部委託
リスク保有（受容）	対策せず**受け入れる**	影響が小さく、対策費のほうが高い

残留リスク：対応した後に残るリスク。受け入れるかはリスク所有者が決める。

リスクファイナンシング：損失が起きたときのお金の手当て（保険・積立て）。損失自体を減らすのはリスクコントロール。

迷いどころ：「サービスを続けたまま対策する」なら低減、「やめる」なら回避。保険に入っても責任までは移らない。

CSIRTは自社のシステム、PSIRTは自社の製品

組織	対象	すること
CSIRT	自組織の情報システム	インシデントの受付・対応・社外窓口
PSIRT	顧客に提供した製品	製品の脆弱性対応・修正・通知
SOC	自組織のNW・機器	ログを24時間監視して検知

R7秋 問40 PSIRTが対応するのは？	
顧客に販売した製品とその利用	**PSIRT**
製品の在庫管理システム	CSIRT
製品の販売管理システム	CSIRT
従業員の個人情報のシステム	CSIRT

CSIRTガイドの6分類（R5秋 問39）：組織内CSIRT／国際連携CSIRT／**コーディネーションセンター（他のCSIRTとの連携・調整）**／分析センター（傾向分析・マルウェア解析）／ベンダーチーム（自社製品＝PSIRT）／インシデントレスポンスプロバイダー（有償で請け負う）

「製品」という言葉に釣られない。社内の業務システムならCSIRT。R6春 問39も「自社製品の脆弱性」→PSIRT。

⚠ 脆弱性情報は「IPAが受け、JPCERT/CCが調整し、JVNで公表」

発見者
脆弱性を見つける
→
IPA
届出を受け付ける
→
JPCERT/CC
製品開発者と調整
→
製品開発者
対策を作り、公表日を調整して決める
→
JVN
脆弱性情報と対策を公表

組織の見分け（R3春 問42）	
JPCERT/CC	独立組織。インシデントの受付・対応支援・手口の分析・助言
NISC	内閣官房。国の司令塔（2025年7月に国家サイバー統括室へ改組）
CRYPTREC	電子政府推奨暗号の評価・監視
JISC	JISを審議する日本産業標準調査会

JVNの目的（R4秋 問40）	
脆弱性関連情報と対策情報を提供	**JVN**
脆弱性を検出する	脆弱性診断
汎用的な評価手法	CVSS
脆弱性のタイプの識別基準	CWE

R3秋 問38：通知を受けた製品開発者は「公表のスケジュールをJPCERT/CCと調整し、決定する」。統計の公表やJVNへの書込みは開発者の仕事ではない。

ガイドライン・制度は「誰が・誰のために作ったか」で見分ける

名前	中身	過去問
サイバーセキュリティ経営ガイドライン	経営者が認識すべき**3原則**と、担当幹部に指示すべき**重要10項目**（経済産業省・IPA）	R3春 問41
JIS Q 27001	ISMSの要求事項（方針・ルール・CIAの維持管理）	同 誤り
COBIT	ITガバナンスとITマネジメントに分けた40のプロセス	同 誤り
サイバーセキュリティ基本法	施策の基本理念と国などの責務	同 誤り
IoTセキュリティガイドライン	要点17「出荷後も安全に」＝アップデートの方法・機能・実施	R3秋 問37
ISMAP	政府が調達する**クラウドサービス**を事前に評価・登録	R5春 問39
CSIRTマテリアル	CSIRTの構築支援資料（**JPCERT/CC**作成）	R4秋 問39
PCI DSS	クレジットカード情報を守るための業界の基準	R3秋 問41 誤り

作成者の組合せ（R4秋 問39）：ISMSユーザーズガイド＝JIPDEC、証拠保全ガイドライン＝デジタル・フォレンジック研究会、内部不正防止ガイドライン＝IPA。

第3章

セキュリティ技術評価

CVE・CWE・CVSS・CCE ／ ファジング ／ 耐タンパ性 ／ コモンクライテリア



Cで始まる4つは「番号・種類・点数・設定」

名前	表すもの	覚え方・例	過去問
CVE	個々の脆弱性の**識別番号**	Vulnerabilities＝脆弱性そのもの。CVE-2024-12345	R5春 問40、R6秋 問41
CWE	脆弱性の**種類（タイプ）**	Weakness＝弱点の型。CWE-79はXSS	R4秋 問40 誤り
CVSS	深刻度の**点数**（0.0〜10.0）	Scoring＝点数。基本・現状・環境の3基準	R3秋 問41
CCE	セキュリティの**設定項目**	Configuration＝設定	R5春 問40 誤り

R3秋 問41：「基本評価基準・現状評価基準・環境評価基準」で評価 → CVSS。誤りの選択肢はISMS・PCI DSS・PMS（個人情報保護マネジメントシステム）。

検査の種類：脆弱性診断＝弱点を網羅的に調べる。ペネトレーションテスト＝実際に侵入を試みる。バグバウンティ＝見つけた人に報奨金。

ファジングは「変なデータを大量に入れて、挙動を見る」

3回出題（R4春 問45、R4秋 問45、R5秋 問46）	
選択肢に並ぶもの	**正体**
問題を起こしそうなデータを入力し挙動を監視	**ファジング**
FINパケットを送り稼働サービスを探す	ポートスキャン
ログを解析してファイルの改ざんを検知	ホスト型IDS
パケットを攻撃パターンと照合	ネットワーク型IDS
大量のリクエストで処理量を測る	負荷テスト
特別な意味の文字を置き換える	エスケープ処理
境界の値をテストデータにする	限界値分析

ポートスキャンの判定（R7秋 問43）		
送る	**返ってくる**	**判定**
TCP SYN	SYN/ACK	開いている
TCP SYN	RST/ACK	閉じている
UDP	ICMP port unreachable	**閉じている**
UDP	応答なし	開いている可能性

> port unreachable＝「そのポートには届かない」なので閉じている。

耐タンパ性は「中を開けられたら消す」。予備機や暗号化通信ではない

3回出題（R3秋 問40、R3春 問46＝R6春 問44）	
正解	プローブの取付けやケースの開封を検知したら、チップ内の秘密情報を消去する
誤り	非接触で便利にする（利便性）
誤り	予備カード・予備機に差し替える（可用性）
誤り	退職者のカードを止める（運用管理）
誤り	軽い暗号で通信を守る・GPSで探す

製品のセキュリティ評価の制度	
ISO/IEC 15408（CC）	IT製品のセキュリティ評価の国際規格
PP	製品の種類ごとのセキュリティ要件
EAL	評価の**厳密さ**の7段階（1が低い）
JISEC	15408に基づく日本の評価・認証制度
JCMVP	**暗号モジュール**の試験・認証制度

TPM・セキュアエレメントも耐タンパ性をもつチップ。鍵を外から取り出せないことが価値。

第4章

情報セキュリティ対策

防御製品の見分け ／ ランサムウェア対策 ／ TPM・セキュアブート ／ SBOM ／ フォレンジックス



防御製品は「どこを見るか」で見分ける

製品	見るもの・すること	過去問での出方
ファイアウォール	IPアドレス・ポート番号で通すか決める	
WAF	Webアプリへの**HTTPの中身**を検査	REST APIへの攻撃に有効（R4秋 問42・R6春 問41）
IDS／IPS	不正な通信を検知して知らせる／遮断する	R4春 問45の誤り
UTM	FW・IPS・マルウェア対策などを**1台に統合**	R5春 問41・R7秋 問42の誤り
SIEM	ログを集めて**相関分析**・通知	R5春 問41・R6秋 問43の誤り
EDR	端末の振る舞いを監視し、侵入後に検知・対応	
CASB	従業員の**クラウド利用**を見える化・制御	R7秋 問42の誤り
CSPM	クラウドの**設定**を監視し、不備を直す	R7秋 問42の正解

WAFで防げないもの：DNSキャッシュポイズニング、メールの第三者中継、メール爆弾（どれもHTTPではない）。

☠ ランサムウェアには「書き換えられないバックアップ」

R5秋 問43	
WORMストレージにバックアップ	**正解**。一度書いたら変更・削除できない
RAID5	故障には強いが、暗号化も全体に反映
常時レプリケーション	暗号化されたデータも複製される
ネットワークドライブ	PCから書けるので一緒に暗号化

3-2-1ルール：コピー3つ・媒体2種類・1つは別の場所（オフライン）。

マルウェアの検出方法	
方法	**未知**
パターンマッチング（定義ファイルと照合）	×
ビヘイビア法（動かして振る舞いを見る）	○
ヒューリスティック法（命令の並びから推測）	○
サンドボックス（隔離環境で実行）	○

VDI（Webアイソレーション）：PCには画面の**画像だけ**を送るので、未知のマルウェアも届かない（R4春 問44）。

TPM・セキュアブート・SBOM・フォレンジックスの決め手

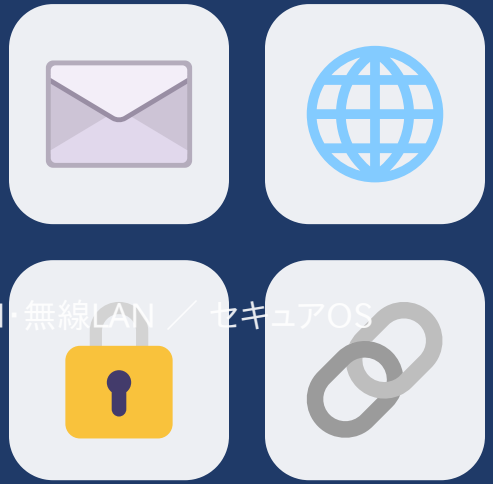
用語	決め手の一文	誤りの選択肢に出たもの
TPM（R5春 問41）	PCに搭載され、鍵生成・ハッシュ演算・暗号処理を行う**チップ**	送信ドメイン認証、UTM、SIEM
セキュアブート（R5秋 問42）	起動時にOSやドライバの**デジタル署名を検証**し、有効なものだけ実行	BIOSパスワード、HDDパスワード、起動後のスキャン
SBOM（R6秋 問43・R7春 問40）	ソフトウェアの**部品表**。コンポーネントと依存関係の一覧 → **脆弱性管理**に使う	SIEM、IT資産台帳、アカウント管理、バージョン管理
デジタルフォレンジックス（R5春 問42＝R7秋 問44）	収集・検査・分析・報告。**削除されたログを復元**して痕跡を見つける	リアルタイム相関分析（SIEM）、メールの暗号化、ハッシュでマルウェア検査
セキュリティクリアランス（R7春 問39）	秘密情報を扱う予定の人の**適性を評価**	ネットワーク分離、アクセス権の棚卸し、クリアデスク

DMZに置くもの（R3秋 問45）：両側のネットワークと通信が必要な機器。制御システムなら、情報ネットワークから更新を入手して配る**パッチ管理サーバ**。

第5章

セキュリティ実装技術

メールのなりすまし対策 ／ DNSSEC ／ IPsec・TLS・VPN ／ cookie ／ VLAN・無線LAN ／ セキュアOS



SPFはIPアドレス、DKIMはデジタル署名、DMARCはポリシー

技術	しくみ	誰が	過去問
SPF	送信元ドメインのDNSに登録した**IPアドレス**と、送ってきたサーバのIPアドレスを照合	受信側	R4秋 問44＝R6春 問43
DKIM	送信側**メールサーバ**がヘッダに**署名**、受信側がDNSの公開鍵で検証	送信サーバ→受信サーバ	R5秋 問44、R7秋 問45
DMARC	SPF・DKIMに失敗したメールの扱い（何もしない・隔離・拒否）を宣言し、報告を受ける	送信ドメインの管理者	R5秋 問44 誤り
SMTP-AUTH	送信時に利用者IDとパスワードで送信者を認証	送信サーバ	R5春 問44
サブミッションポート	**587番**でSMTP-AUTHをしてから受け付ける	送信サーバ	R5春 問44
OP25B	ISPが外向きの**25番**を遮断し、スパムの直接送信を防ぐ	ISP	R7秋 問45 誤り
S/MIME	**利用者**が本文を暗号化・署名	利用者	R7秋 問45 誤り

DKIMとS/MIMEの見分け：どちらも署名だが、DKIMは**メールサーバ**がドメイン単位で、S/MIMEは**利用者**が自分で付ける。

DNSSECは「署名で正しさを確かめる」。暗号化はしない

権威DNSサーバ
秘密鍵でリソースレコードに署名、公開鍵を公開

→

DNSキャッシュサーバ
公開鍵で署名を検証

→

改ざんされた応答を見抜く
キャッシュポイズニングに強い

選択肢に並ぶもの	正体
公開鍵暗号によるデジタル署名で、正当な応答か検証	**DNSSEC**（R5秋 問45・R6春 問37・R6秋 問44）
送信元ポート番号を問合せのたびにランダムに	キャッシュポイズニング対策だがDNSSECではない
再帰問合せを許可するクライアントを制限	オープンリゾルバ対策
共通鍵のメッセージ認証で検証	DNSSECは公開鍵。共通鍵ではない
権威サーバとキャッシュサーバの通信を暗号化	DNSSECは暗号化しない
メールサーバのIPアドレス／公開鍵をDNSに登録	SPF／DKIM

VPNのプロトコルは上から TLS → IPsec → L2TP

アプリケーション層
SSH・S/MIME

トランスポート層（の上）
TLS（SSL-VPN・HTTPS）

ネットワーク層
IPsec（AH・ESP）

データリンク層
L2TP（暗号化はIPsecと組み合わせる）・PPP

問われ方	答え
ネットワーク層でAHとESPを含む（R3秋 問43）	IPsec
IPv6の拡張ヘッダで実現できる機能（R3秋 問36）	暗号化通信
IPv6でネットワーク層の暗号化（R6春 問42）	IPsec
IPsec・L2TP・TLSの位置関係（R7春 問43）	上から TLS／IPsec／L2TP

AHとESP：AHは認証と改ざん検知だけ、ESPは暗号化もする。

🔗 cookieの属性は「いつ送るか・誰に読ませるか」

R7春 問41 Secure属性	
属性	**効果**
Secure	**HTTPSのときだけ**送る
HttpOnly	JavaScriptから読めない（XSS対策）
SameSite	他サイトからのリクエストに付けない（CSRF対策）
Expires	有効期限
Path	送るURLのパスの範囲

セッションとヘッダ	
ログアウト時	サーバでセッションIDを**無効**にする（R3春 問44）
サードパーティcookieをブロック	サイトをまたいだ**トラッキング**を防ぐ（R4春 問40）
X-Frame-Options	クリックジャッキング対策（R3春 問37）
HSTS	今後はHTTPSだけで接続させる

R3春 問44の罠：ブラウザのキャッシュを消しても、サーバ側のセッションIDが有効なら乗っ取られる。

ネットワークの守りは「何で見分けて、何を分けるか」

技術	しくみ	過去問
認証VLAN	利用者を認証してVLANを**動的**に割り当てる	フリーアドレスで幹部だけ（R5春 問45）
スタティックVLAN	ポートごとに**固定**でVLANを決める	同 誤り（席が変わると使えない）
VLANでセグメント分割	**ブロードキャスト**の届く範囲を制限	R6秋 問45
MACアドレスフィルタリング	登録したMACアドレスだけ接続。**偽装**は防げない	R5春 問43 誤り
プライバシーセパレータ	同じアクセスポイントの**端末どうし**の通信を遮断	公衆無線LAN（R5春 問43）
IPマスカレード（NAPT）	外から内部の端末へ直接接続を始められない	家庭のルータ（R4秋 問43）
セキュアOS	**強制アクセス制御**で、侵入されても改ざんを防ぐ	R5春 問37

R5春 問43の罠：SSIDは暗号化できない。自社ドメイン名をSSIDにしても、同じ名前の偽アクセスポイントは作れる。

試験で狙われやすい比較10選（1/2）

	比較	見分ける一言
1	機密性 vs 可用性	「認可されていない者に使わせない」が機密性、「認可された者が要求したとき使える」が可用性
2	真正性 vs 信頼性 vs 否認防止	主張するとおりのもの／行動と結果が一貫／利用した事実を後から証明できる
3	サイドチャネル攻撃 vs 解読法	電力・時間・電磁波など**物理量**ならサイドチャネル。線形近似・差分・選択平文は数学
4	署名鍵 vs 検証鍵	署名鍵＝送信者の秘密鍵で**作る**。検証鍵＝送信者の公開鍵で受信者が**確かめる**
5	CRL vs OCSP	CRLは失効した証明書の**一覧**（有効期限内のもの）。OCSPは**1件ずつ問合せ**

どれも、過去問で正解と誤りの選択肢として**同じ問題に並んだ**組合せ。

試験で狙われやすい比較10選（2/2）

	比較	見分ける一言
6	SPF vs DKIM vs DMARC	IPアドレスで照合／メールサーバの署名を検証／失敗時の扱いを宣言して報告を受ける
7	DNSSEC vs ポートのランダム化 vs 再帰問合せの制限	署名で検証／偽応答を当てにくくする／オープンリゾルバにしない
8	CSIRT vs PSIRT vs SOC	自社のシステム／顧客に売った製品／ログを監視して検知
9	リスク特定 vs 分析 vs 評価	資産や資源の性質・価値を考慮して洗い出す／起こりやすさ×結果でレベル／基準と比べて優先順位
10	ソルト vs ストレッチング	利用者ごとの文字列を**付け足す**／ハッシュ化を**繰り返す**

おまけ：CVE（番号）・CWE（種類）・CVSS（点数）・CCE（設定）、CASB（使い方）・CSPM（設定）、認証VLAN（動的）・スタティックVLAN（固定）。

出典

過去問

IPA 応用情報技術者試験 午前 問題冊子・解答例（令和3年度春期〜令和7年度秋期の10回分）。セキュリティの問題101問を1問ずつ読み、正解と誤りの選択肢を確認した。IPAの過去問題は許諾・使用料なしで利用できる（IPA「過去問題」ページ）

シラバス

IPA「応用情報技術者試験（レベル3）シラバス Ver.7.2」中分類11 セキュリティ（小分類1〜5の用語例）

定義文

JIS Q 27000:2019・JIS Q 31000:2019の定義は、過去問の選択肢に出た表現をそのまま使った

イラスト

Microsoft Fluent Emoji（MIT License）。ライセンス全文は tools/slides/img/security/LICENSE-fluentui-emoji.txt

作成

上の資料をもとにClaudeがまとめた。解説はIPAの公式解説ではなく、Claudeが自分の言葉で書いたもの。サイトの用語集（276語）と問題演習（98問）も同じ資料から作っている